

Executive Security Report

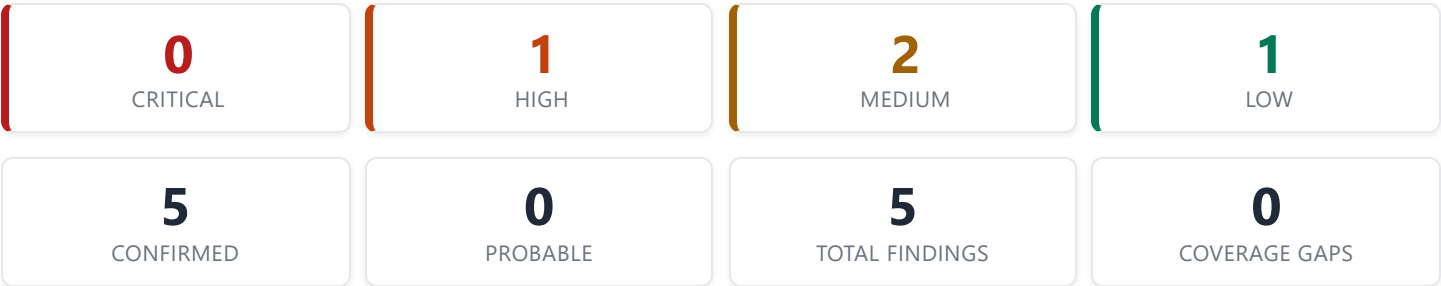
RFC Buddy - OCIO 365-Day Schedule Filter & CAB Document Generator (RFCBuddy)

Report Date: 2026-07-31

Overall Risk: HIGH

Quality Gate: PASSED

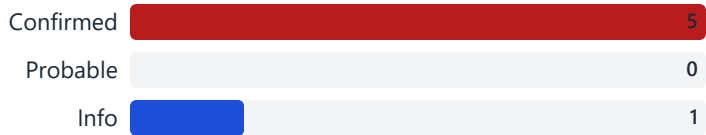
Key Metrics



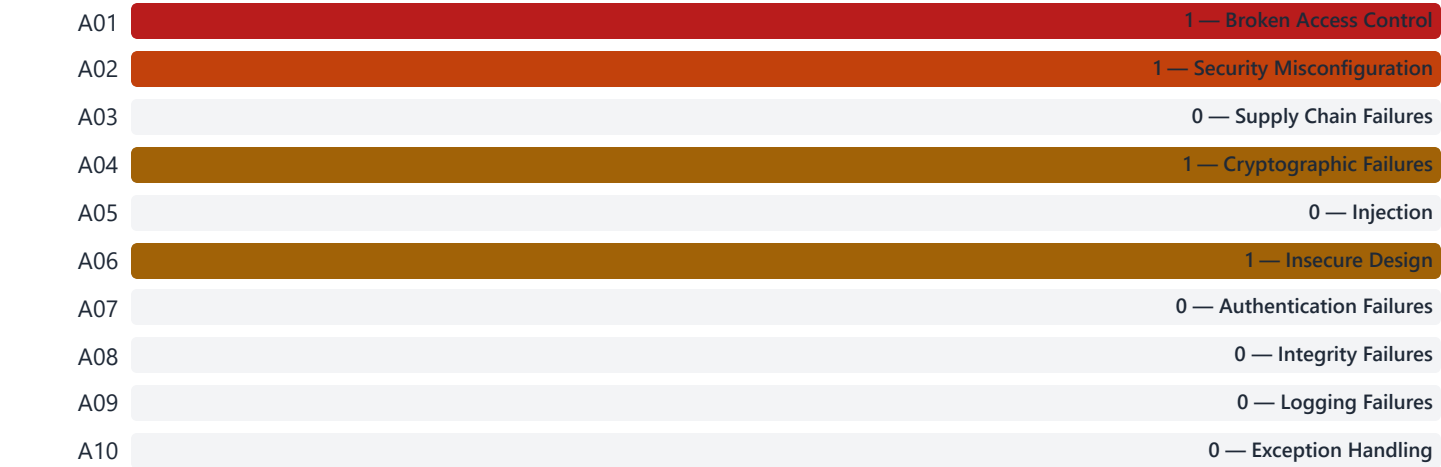
Findings by Severity



Classification



Findings by OWASP Category



Executive Brief

The latest security review assigns RFC Buddy a HIGH overall risk rating and records five confirmed findings: one high, two medium, one low, and one informational. The detailed findings state that all five have been remediated, and the SonarQube quality gate passed with zero open vulnerabilities, bugs, or code smells. This indicates a materially improved posture, but deployment verification and remediation evidence remain leadership priorities.

High-Risk Security Issues

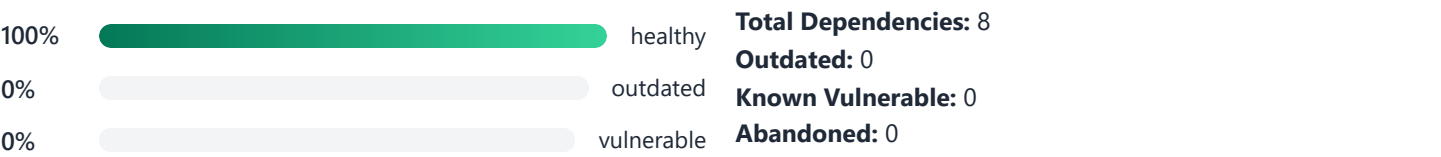
Critical and high-severity findings requiring immediate attention. Confirmed findings have full code evidence; Probable findings await complete verification.

Finding	Severity	Class.	Business Risk	Action
User identity collision risk via non-unique OIDC display name	HIGH	Confirmed (Remediated)	Before remediation, users with the same display name could have shared identity records, potentially exposing another user's settings, API tokens, or administrator privileges.	Verify deployment of unique OIDC identifier mapping and automatic migration of legacy user, token, and data hashes.

Technical Debt & Platform Currency

Component	Category	Risk	Impact	Action
Security remediation deployment verification	Operational Risk	HIGH	Five confirmed findings are marked remediated; until production deployment and regression evidence are verified, the prior access-control and transport risks remain material.	Confirm the remediated branch is deployed, rerun security tests, and retain evidence for all five completed remediations.
Automated test coverage	Quality Assurance	MEDIUM	Measured unit-test coverage is 60.1%, leaving meaningful behavior less protected by automated regression tests.	Increase targeted coverage for authentication, authorization, persistence, and background-worker failure paths.

Dependency Health



STRIDE Threat Model

Component	Spoofing	Tampering	Repudiation	Info Disclosure	DoS	Elevation
Web UI / OIDC	Low	Low	Medium	Medium	Low	Medium

Component	Spoofing	Tampering	Repudiation	Info Disclosure	DoS	Elevation
PAT REST API	Medium	Medium	Medium	Medium	Medium	Medium
Shared data volume and background workers	Low	Medium	Low	Medium	Medium	Low

Architecture Overview

Tech Stack: .NET 10 / ASP.NET Core MVC and REST API, Keycloak OIDC, OpenXML/DocX, JSON file stores, Docker, OpenShift/Kubernetes

Architecture: ASP.NET Core MVC web application with PAT-authenticated REST API and hosted background workers

Deployment: Docker containers deployed through GitHub Actions and GitOps to OpenShift Emerald

Resilience: Two-replica active-active deployment with shared persistent storage and DataProtection keys, PVC snapshots, inferred RTO under 5 minutes, and inferred RPO under 24 hours

Assessment Coverage



Strategic Remediation Roadmap

- P1 Immediate — Current Sprint**
Verify production deployment and independent regression evidence for all five confirmed remediations, prioritizing the identity collision fix and its legacy data migration.
- P2 Short Term — 1-2 Sprints**
Confirm HTTPS metadata enforcement, security headers, API rate limiting, and regex escaping are active in deployed environments; rerun the security scan.
- P3 Strategic — Next Quarter**
Raise automated coverage above 60.1% and exercise PVC backup/restore procedures, especially for authentication, persistence, and background-worker failure paths.